

CAHIER DES CHARGES

Plateforme SaaS de Gestion des Identités
et des Accès Privilégiés

IAM & PAM as a Service

Type de projet	Projet de Fin d'Études (PFE)
Durée	6 mois (Janvier 2026 - Juin 2026)
Domaine	Cybersécurité - Cloud
Version	1.0 - Janvier 2026

Table des matières

1. Contexte et Problématique	4
1.1 Contexte général	4
1.2 Problématiques identifiées.....	4
1.3 Enjeux stratégiques	4
2. Objectifs du Projet.....	5
2.1 Objectif principal	5
2.2 Objectifs fonctionnels.....	5
2.3 Objectifs techniques	5
3. Périmètre du Projet	6
3.1 Inclus dans le périmètre.....	6
3.2 Hors périmètre.....	6
4. Architecture Technique	7
4.1 Architecture globale	7
4.2 Stack technologique	7
4.3 Flux d'authentification (SSO)	7
4.4 Flux d'accès PAM.....	7
5. Spécifications Fonctionnelles Détaillées.....	8
5.1 Module IAM	8
5.1.1 Authentification	8
5.1.2 RBAC.....	8
5.2 Module PAM.....	8
5.2.1 Gestion des ressources.....	8
5.2.2 Sessions PAM.....	8
5.3 Application Web.....	8
6. Planning Détaillé (6 mois)	9
7. Risques et Stratégies de Mitigation	10
8. Livrables	11
8.1 Livrables techniques	11
8.2 Documentation	11
8.3 Rapport et présentation	11
9. Indicateurs de Succès (KPIs)	11
9.1 KPIs fonctionnels.....	11

10. Conclusion et Perspectives	12
10.1 Synthèse du projet.....	12
10.2 Valeur ajoutée	12
Annexes.....	13
Annexe A - Glossaire.....	13

1. Contexte et Problématique

1.1 Contexte général

Dans un environnement numérique en constante évolution, la sécurisation des identités et des accès constitue un enjeu majeur pour les entreprises. Les organisations modernes font face à une complexité croissante dans la gestion de leurs systèmes d'information, caractérisée par une infrastructure hybride combinant environnements cloud et on-premise, une multiplication des applications et services, ainsi qu'un nombre croissant d'utilisateurs et d'administrateurs nécessitant des accès à des ressources critiques.

Les secteurs sensibles tels que les banques, les institutions financières et les grandes organisations sont particulièrement exposés aux risques de sécurité et doivent répondre à des exigences réglementaires strictes en matière de protection des données et de traçabilité des accès.

1.2 Problématiques identifiées

Les entreprises rencontrent plusieurs défis critiques :

- **Accès directs non contrôlés** : Les administrateurs accèdent directement aux serveurs via SSH ou RDP sans contrôle centralisé.
- **Comptes privilégiés partagés** : L'utilisation de comptes administrateurs partagés rend impossible l'identification individuelle.
- **Traçabilité insuffisante** : L'absence de journalisation centralisée complique les audits de sécurité.
- **Politiques de sécurité hétérogènes** : Difficulté d'appliquer des règles uniformes sur l'ensemble de l'infrastructure.
- **Exigences de conformité** : Les réglementations (ISO 27001, PCI-DSS, SOC 2, GDPR) imposent des contrôles stricts.
- **Gestion multi-tenant complexe** : Pour les MSP, la gestion sécurisée de multiples clients avec isolation des données.

1.3 Enjeux stratégiques

- **Sécurité** : Réduire la surface d'attaque en éliminant les accès directs.
- **Conformité** : Faciliter la conformité aux référentiels réglementaires.
- **Opérationnel** : Simplifier la gestion quotidienne des accès.

2. Objectifs du Projet

2.1 Objectif principal

Concevoir, développer et déployer une plateforme SaaS multi-tenant de gestion centralisée des identités (IAM) et des accès privilégiés (PAM), permettant aux entreprises de sécuriser, contrôler et auditer l'ensemble des accès à leurs systèmes d'information, tout en garantissant une isolation stricte des données clients et une conformité réglementaire.

2.2 Objectifs fonctionnels

1. Authentification centralisée avec SSO et MFA obligatoire
2. Système RBAC granulaire par tenant
3. Bastion sécurisé pour accès SSH/RDP indirect
4. Gestion des accès temporaires avec workflows d'approbation
5. Journalisation complète et centralisée
6. Interface web intuitive pour gestion et consultation

2.3 Objectifs techniques

7. Architecture multi-tenant avec isolation stricte
8. Déploiement conteneurisé (Docker/Kubernetes)
9. Sécurité des communications (HTTPS/TLS)
10. Intégration avec systèmes d'identité existants (AD, LDAP, Azure AD)
11. Gestion sécurisée des secrets avec rotation automatique

3. Périmètre du Projet

3.1 Inclus dans le périmètre

- **Module IAM** : SSO, MFA, RBAC, intégration LDAP/AD
- **Module PAM** : Accès SSH/RDP via bastion, gestion secrets
- **Application Web** : Frontend + Backend, dashboards, workflows
- **Bastion sécurisé** : Proxy SSH/RDP, isolation réseau
- **Journalisation** : Logs centralisés, rapports audit
- **Infrastructure** : Docker, Kubernetes, CI/CD
- **Documentation** : Architecture, guides, rapport projet

3.2 Hors périmètre

- Haute disponibilité multi-datacenter
- Scalabilité massive (milliers de tenants)
- Intégration SIEM complète
- Gestion complète du cycle de vie utilisateurs
- Support de tous les protocoles (limité à SSH/RDP)
- Enregistrement vidéo des sessions
- Intelligence artificielle et ML

4. Architecture Technique

4.1 Architecture globale

La plateforme adopte une architecture microservices conteneurisée, orchestrée par Kubernetes.

- **Couche présentation** : Application web SPA (Angular/React)
- **Couche application** : Backend REST API (Spring Boot)
- **Couche identité** : Serveur Keycloak (SSO, MFA)
- **Couche PAM** : Bastion Linux durci (proxy SSH/RDP)
- **Couche données** : PostgreSQL avec schémas par tenant
- **Couche logs** : Système centralisé de logs

4.2 Stack technologique

Frontend	Angular / React
Backend	Spring Boot 3.x
IAM	Keycloak
Authentification	OAuth 2.0 / OIDC
Tokens	JWT
Base de données	PostgreSQL
Bastion	Linux + OpenSSH
Conteneurs	Docker
Orchestration	Kubernetes
Logs	Logs applicatifs + ELK (optionnel)

4.3 Flux d'authentification (SSO)

12. L'utilisateur accède à l'application et clique sur "Se connecter"
13. Redirection vers Keycloak avec requête OAuth2
14. Keycloak demande identifiants + MFA
15. Génération code d'autorisation après succès
16. Application échange le code contre JWT
17. JWT contient claims (tenant_id, rôles, permissions)
18. Chaque requête API inclut le JWT
19. Backend valide JWT et applique RBAC

4.4 Flux d'accès PAM

20. Utilisateur demande accès à une ressource via interface web
21. Vérification permissions RBAC + workflow approbation
22. Génération session temporaire avec durée limitée
23. Bastion récupère credentials depuis vault sécurisé
24. Connexion au bastion avec identité utilisateur
25. Bastion établit connexion SSH/RDP vers cible
26. Journalisation en temps réel des actions
27. Révocation automatique à expiration

5. Spécifications Fonctionnelles Détaillées

5.1 Module IAM

5.1.1 Authentification

- **SSO** : Authentification unique pour tous les services
- **MFA obligatoire** : Support TOTP, SMS, email
- **Intégration LDAP/AD** : Fédération avec annuaires existants
- **Politiques mot de passe** : Complexité, expiration, historique
- **Gestion sessions** : Timeout, refresh token, déconnexion unique

5.1.2 RBAC

- Rôles prédéfinis : Super Admin, Tenant Admin, Auditeur, Utilisateur, Admin Système
- Permissions granulaires : Lecture, écriture, suppression, approbation, audit
- Rôles personnalisés par tenant
- Héritage de rôles possible
- Isolation stricte entre tenants

5.2 Module PAM

5.2.1 Gestion des ressources

- Enregistrement serveurs SSH, postes RDP, bases de données
- Catégorisation par environnement (Prod, Staging, Dev)
- Tags et métadonnées pour recherche
- Gestion centralisée des credentials (vault)
- Rotation automatique des mots de passe

5.2.2 Sessions PAM

- Connexion via bastion uniquement
- Support SSH et RDP
- Injection automatique des credentials
- Journalisation temps réel des commandes
- Déconnexion automatique à expiration
- Révocation manuelle possible

5.3 Application Web

- **Connexion** : SSO, MFA, récupération mot de passe
- **Dashboard** : Vue d'ensemble, statistiques, sessions actives
- **Catalogue ressources** : Liste serveurs, recherche, demande accès
- **Mes accès** : Sessions actives, historique
- **Administration** : Gestion utilisateurs, rôles, ressources
- **Audit** : Consultation logs, recherche, export rapports

6. Planning Détaillé (6 mois)

Phase	Période	Activités principales
Mois 1	Janvier 2026	Analyse besoins, CDC, architecture, UML, setup environnement
Mois 2	Février 2026	Installation Keycloak, SSO, MFA, intégration JWT
Mois 3	Mars 2026	Backend Spring Boot, RBAC, Frontend, dashboards, tests
Mois 4	Avril 2026	Bastion Linux, proxy SSH/RDP, vault, workflows PAM
Mois 5	Mai 2026	Module logs, interface audit, Docker, Kubernetes, CI/CD
Mois 6	Juin 2026	Tests sécurité, performance, documentation, rapport, maintenance

7. Risques et Stratégies de Mitigation

Risque	Impact	Mitigation
Complexité technique sous-estimée	Retard planning	Priorisation MVP, déploiement incrémental
Faible de sécurité critique	Compromission données	Revue code, tests OWASP, audit externe
Isolation tenants insuffisante	Fuite données entre clients	Tests unitaires isolation, validation POC
Problèmes intégration Keycloak	Authentification défailante	POC Keycloak mois 2, documentation
Complexité Kubernetes	Difficultés déploiement	Formation K8s, utilisation Minikube/K3s
Manque expertise technologies	Code qualité médiocre	Formation continue, support encadrant

8. Livrables

8.1 Livrables techniques

- Code source complet (dépôt Git)
- Images Docker (Backend, Frontend, Keycloak, Bastion)
- Manifestes Kubernetes (Deployments, Services, Ingress, ConfigMaps)
- Pipeline CI/CD

8.2 Documentation

- Documentation architecture (UML, diagrammes, schémas)
- Guide d'installation
- Documentation utilisateur (manuels admin/utilisateur)
- Documentation API (OpenAPI/Swagger)

8.3 Rapport et présentation

- Rapport de projet complet (100-150 pages)
- Présentation soutenance (PowerPoint, 30-40 slides)
- Démonstration fonctionnelle (vidéo + démo live)

9. Indicateurs de Succès (KPIs)

9.1 KPIs fonctionnels

- 100% fonctionnalités critiques implémentées (IAM, PAM, Audit)
- Support de 10 tenants simultanés minimum
- Gestion de 100 utilisateurs par tenant
- Temps moyen demande d'accès < 30 secondes

10. Conclusion et Perspectives

10.1 Synthèse du projet

Ce projet de fin d'études vise à concevoir et développer une plateforme SaaS innovante de gestion des identités et des accès privilégiés, répondant aux enjeux critiques de cybersécurité des entreprises. En combinant IAM et PAM dans une solution unifiée multi-tenant, ce projet propose une approche holistique de la sécurisation des accès aux systèmes d'information.

10.2 Valeur ajoutée

- **Sécurité** : Réduction drastique des risques liés aux accès non contrôlés
- **Conformité** : Facilitation des audits et certifications
- **Opérationnel** : Simplification de la gestion quotidienne
- **Pédagogique** : Acquisition de compétences avancées en cybersécurité

Annexes

Annexe A - Glossaire

Terme	Définition
IAM	Identity and Access Management - Gestion des identités et des accès
PAM	Privileged Access Management - Gestion des accès privilégiés
SSO	Single Sign-On - Authentification unique
MFA	Multi-Factor Authentication - Authentification multi-facteurs
RBAC	Role-Based Access Control - Contrôle d'accès basé sur les rôles
JWT	JSON Web Token - Token d'authentification standardisé
Bastion	Serveur d'accès sécurisé servant de point de passage obligatoire
Tenant	Client ou organisation dans une architecture multi-tenant
OIDC	OpenID Connect - Protocole d'authentification basé sur OAuth 2.0

--- FIN DU DOCUMENT ---

Signature
Ben Tahar Omar

Signature Mme
Belghith Mouna